

Web Application Security Testing Guide

By BabaShaheer

1. Introduction

This guide provides instructions for setting up and using two popular vulnerable web application environments: OWASP Broken Web Application (BWA) Project and Metasploitable 2. These environments are designed for security professionals, developers, and enthusiasts to practice identifying and exploiting common web application vulnerabilities in a safe, legal environment.

We'll use Kali Linux as our testing platform, which comes pre-installed with numerous security testing tools.

2. Setting Up VirtualBox

2.1 Download and Install VirtualBox

1. Download VirtualBox from the official website: <https://www.virtualbox.org/wiki/Downloads>
2. Install VirtualBox by following the installation wizard
3. Install the VirtualBox Extension Pack for additional functionality

2.2 Configure VirtualBox Network Settings

For our lab environment, we'll create an isolated network where our machines can communicate with each other but remain separated from your regular network.

1. Open VirtualBox
2. Go to File → Preferences → Network
3. Click on the “+” icon to add a new NAT Network
4. Name it “Security Lab Network”
5. Set the Network CIDR to “10.0.2.0/24”
6. Check “Enable Network”
7. Click “OK” to save

3. Installing Metasploitable 2

Metasploitable 2 is an intentionally vulnerable Ubuntu Linux virtual machine containing numerous security vulnerabilities for testing purposes.

3.1 Download Metasploitable 2

1. Download Metasploitable 2 from: <https://sourceforge.net/projects/metasploitable/files/Metasploitable2/>
2. Extract the .zip file to get the VM files

3.2 Import Metasploitable 2 to VirtualBox

1. Open VirtualBox
2. Go to Machine → Add
3. Navigate to the extracted Metasploitable folder and select the .vmdk file
4. Click “Open”

3.3 Configure Metasploitable 2 VM

1. Select the newly added VM
2. Right-click and select “Settings”
3. Under “System”, ensure at least 512MB RAM is allocated
4. Under “Network”, select “NAT Network” and choose “Security Lab Network”
5. Click “OK” to save settings

3.4 Start and Verify Metasploitable 2

1. Select the VM and click “Start”
2. Wait for the boot process to complete
3. Default login credentials:
 - Username: `msfadmin`
 - Password: `msfadmin`
4. Run `ifconfig` to verify the IP address (note it for later)

4. Installing OWASP Broken Web App (BWA)

The OWASP BWA is a collection of vulnerable web applications for security testing practice.

4.1 Download OWASP BWA

1. Download OWASP BWA from: <https://sourceforge.net/projects/owaspbwa/files/>
2. Download the latest .ova file

4.2 Import OWASP BWA to VirtualBox

1. Open VirtualBox
2. Go to File → Import Appliance
3. Browse to the downloaded .ova file
4. Click “Next”
5. Keep default settings and click “Import”

4.3 Configure OWASP BWA VM

1. Select the imported VM
2. Right-click and select “Settings”
3. Under “System”, ensure at least 1GB RAM is allocated
4. Under “Network”, select “NAT Network” and choose “Security Lab Network”
5. Click “OK” to save settings

4.4 Start and Verify OWASP BWA

1. Select the VM and click “Start”
2. Wait for the boot process to complete
3. Default login credentials:
 - Username: `root`
 - Password: `owaspbwa`
4. Run `ifconfig` to verify the IP address (note it for later)
5. Open a web browser on your host machine and navigate to the IP address of your OWASP BWA VM
6. You should see the OWASP BWA welcome page with links to various vulnerable applications

5. OWASP Top 10 Overview

The OWASP Top 10 represents the most critical web application security risks. Here’s a brief overview of each:

5.1 Injection

Description: Injection flaws, such as SQL, NoSQL, OS, and LDAP injection, occur when untrusted data is sent to an interpreter as part of a command or query.

Example: SQL Injection in login forms where an attacker enters ' OR 1=1 -- in a username field to bypass authentication.

5.2 Broken Authentication

Description: Application functions related to authentication and session management are often implemented incorrectly, allowing attackers to compromise passwords, keys, or session tokens.

Example: Weak passwords, exposed session IDs, or session fixation attacks.

5.3 Sensitive Data Exposure

Description: Many web applications and APIs do not properly protect sensitive data such as financial, healthcare, or personally identifiable information (PII).

Example: Storing passwords in plain text or transmitting sensitive data over unencrypted connections.

5.4 XML External Entities (XXE)

Description: Older or poorly configured XML processors evaluate external entity references within XML documents, leading to disclosure of internal files, port scanning, or remote code execution.

Example: Including a reference to an external entity in an XML document processed by a vulnerable parser.

5.5 Broken Access Control

Description: Restrictions on what authenticated users are allowed to do are often not properly enforced.

Example: Modifying a URL parameter to access another user's account without proper authorization.

5.6 Security Misconfiguration

Description: This is the most common issue, resulting from insecure default configurations, incomplete configurations, open cloud storage, or verbose error messages.

Example: Default admin credentials left unchanged or unnecessary services running on a server.

5.7 Cross-Site Scripting (XSS)

Description: XSS flaws occur when an application includes untrusted data in a new web page without proper validation.

Example: Injecting a script tag in a comment form that executes when other users view the comment.

5.8 Insecure Deserialization

Description: Insecure deserialization often leads to remote code execution, one of the most serious attacks possible.

Example: A PHP application deserializing user-supplied serialized objects without proper validation.

5.9 Using Components with Known Vulnerabilities

Description: Components, such as libraries, frameworks, and other software modules, run with the same privileges as the application.

Example: Using an outdated version of a JavaScript library with known security vulnerabilities.

5.10 Insufficient Logging & Monitoring

Description: Insufficient logging and monitoring, coupled with missing or ineffective integration with incident response, allows attackers to further attack systems, maintain persistence, and tamper with data.

Example: Failed login attempts not being logged or alerts not being sent when suspicious activities occur.

6. Practical Testing with DVWA

DVWA (Damn Vulnerable Web Application) is included in the OWASP BWA and provides a platform to practice various web vulnerabilities.

6.1 Accessing DVWA

1. Start your OWASP BWA VM
2. Note its IP address
3. On your Kali Linux VM, open a web browser
4. Navigate to `http://{OWASP_BWA_IP}/dvwa/`
5. Default login credentials:
 - Username: `admin`
 - Password: `password`

6.2 Configuring DVWA

1. After logging in, go to “DVWA Security” in the left menu
2. Select security level (Low for beginners, Medium for intermediate, High for advanced)
3. Click “Submit”

6.3 Testing SQL Injection in DVWA

1. Navigate to “SQL Injection” in the left menu
2. In the “User ID” field, enter: `1' OR '1'='1`
3. Click “Submit”
4. You should see information for all users, not just user ID 1

6.4 Testing XSS (Reflected) in DVWA

1. Navigate to “XSS (Reflected)” in the left menu
2. In the “What’s your name?” field, enter: `<script>alert('XSS')</script>`
3. Click “Submit”
4. An alert box should appear, demonstrating successful XSS

6.5 Testing Command Injection in DVWA

1. Navigate to “Command Injection” in the left menu
2. In the “IP address” field, enter: `127.0.0.1; cat /etc/passwd`
3. Click “Submit”
4. You should see both the ping results and the contents of the `/etc/passwd` file

7. Practical Testing with BWAPP

BWAPP (Buggy Web Application) is another vulnerable application included in OWASP BWA with over 100 vulnerabilities.

7.1 Accessing BWAPP

1. On your Kali Linux VM, open a web browser
2. Navigate to `http://{OWASP_BWA_IP}/bwapp/`
3. If this is your first time, click on “Install” to set up the database
4. Default login credentials:
 - Username: `bee`
 - Password: `bug`

7.2 Configuring BWAPP

1. After logging in, select a vulnerability from the dropdown menu
2. Choose a security level (low, medium, high)
3. Click “Hack”

7.3 Testing SQL Injection (GET/Search) in BWAPP

1. Select “SQL Injection (GET/Search)” from the dropdown
2. Set security level to “low”
3. Click “Hack”
4. In the search field, enter: `a' OR 1=1 #`
5. Click “Search”
6. You should see all entries in the database

7.4 Testing Broken Authentication - Weak Passwords in BWAPP

1. Select “Broken Auth. - Weak Passwords” from the dropdown
2. Set security level to “low”
3. Click “Hack”
4. Try common passwords like “123456”, “password”, or “admin”
5. Notice how easily you can guess the password

7.5 Testing Cross-Site Request Forgery (CSRF) in BWAPP

1. Select “CSRF (Change Password)” from the dropdown
2. Set security level to “low”
3. Click “Hack”
4. Create an HTML file on your Kali Linux with the following content:

```
<html>
<body>
<form action="http://{OWASP_BWA_IP}/bWAPP/csrf_1.php" method="GET">
<input type="hidden" name="password_new" value="hacked">
<input type="hidden" name="password_conf" value="hacked">
<input type="hidden" name="action" value="change">
<input type="submit" value="Click me!">
</form>
</body>
</html>
```

5. Open this HTML file in a browser
6. Click the button
7. The password should change without proper authorization

8. Additional Resources

8.1 Tools in Kali Linux for Web App Testing

- **Burp Suite:** Web vulnerability scanner and proxy
- **OWASP ZAP:** Open-source web application security scanner
- **SQLmap:** Automated SQL injection tool
- **Nikto:** Web server scanner
- **Dirb/Dirbuster:** Web content scanner

8.2 Learning Resources

- Official OWASP Website: <https://owasp.org/>
- OWASP Testing Guide: <https://owasp.org/www-project-web-security-testing-guide/>
- Portswigger Web Security Academy: <https://portswigger.net/web-security>
- HackTheBox Web Challenges: <https://www.hackthebox.com/>

8.3 Responsible Disclosure

Remember to only practice these techniques in controlled, legal environments like those set up in this guide. Unauthorized testing against real websites is illegal and unethical.

9. Troubleshooting

9.1 Network Connectivity Issues

- Ensure all VMs are on the same NAT Network
- Verify IP addresses with `ifconfig` or `ip addr show`
- Try pinging between VMs to confirm connectivity

9.2 OWASP BWA Not Starting Properly

- Increase RAM allocation to at least 1GB
- Ensure the VM has at least 8GB of disk space
- Check VM logs for specific errors

9.3 Metasploitable 2 Login Issues

- Default credentials are `msfadmin/msfadmin`
- If that fails, try rebooting the VM
- Check if the keyboard layout is causing input issues

This guide should help you set up a complete web application security testing environment. Remember to practice ethically and never use these skills against systems without explicit permission.

Happy Appsec testing!

BabaShaheer